

RANSOMWARE THREATS TO FINANCIAL INSTITUTIONS

Cybersecurity Risk Assessment White Paper

Document Type:	White Paper / Cybersecurity Risk Assessment
Classification:	Confidential – Regulatory Submission
Prepared by:	Cyber Risk Intelligence & Governance Division
Target Audience:	Reserve Bank of India (RBI) – DPSS / CSITE
Date:	June 2025
Version:	1.0 – Final

ABSTRACT

Ransomware attacks have emerged as one of the most severe and financially devastating cyber threats confronting global financial institutions. This white paper presents a comprehensive risk assessment of ransomware threats targeting the banking and financial services sector, with specific relevance to the Indian financial ecosystem regulated by the Reserve Bank of India (RBI). Drawing on documented case studies, threat intelligence data, and regulatory frameworks, this paper analyses attack vectors, operational impacts, and sector-specific vulnerabilities. The paper further proposes a multi-layered defence strategy aligned with RBI Master Directions on IT Framework and the NIST Cybersecurity Framework. Recommendations are tailored for implementation by Scheduled Commercial Banks, Non-Banking Financial Companies (NBFCs), and Payment System Operators (PSOs).

1. INTRODUCTION

The digital transformation of financial services – accelerated by the COVID-19 pandemic, the rapid proliferation of digital payment systems, and the expansion of mobile banking – has simultaneously expanded the cyber-attack surface of financial institutions. Among the spectrum of cyber threats, ransomware stands apart in its capacity to disrupt operations, destroy data integrity, and extort billions in ransom payments.

According to IBM's Cost of a Data Breach Report 2024, the average total cost of a ransomware breach in the financial sector reached USD 5.9 million – the second highest across all industries. The Ransomware Task Force (RTF) documented a 105% surge in ransomware incidents in 2023 globally, with financial institutions accounting for nearly 18% of all targeted sectors.

For Indian financial institutions, the RBI Cyber Security Framework mandates robust incident response and business continuity capabilities. However, the sophistication of modern ransomware groups – employing double and triple extortion tactics, supply chain compromise, and Ransomware-as-a-Service

(RaaS) models – demands an elevated and continuously updated defensive posture.

2. THREAT LANDSCAPE ANALYSIS

2.1 Evolution of Ransomware Tactics

Modern ransomware has evolved far beyond rudimentary file-encryption malware. Contemporary threat actors operate sophisticated criminal enterprises employing the following progression of techniques:

Gen 1 – Scareware	2005–2012	Fake warnings; minimal encryption; low ransom demands
Gen 2 – Crypto-Ransomware	2013–2017	Strong AES/RSA encryption; Bitcoin payments; WannaCry / NotPetya
Gen 3 – Double Extortion	2018–2021	Exfiltration before encryption; public leak sites; Maze, REvil
Gen 4 – Triple Extortion	2022–Present	DDoS + data leak + supply chain targeting; LockBit 3.0, BlackCat

Table 1: Ransomware Evolution by Generation

2.2 Primary Attack Vectors

Financial institutions are targeted through multiple initial access vectors. Intelligence gathered from incident response engagements identifies the following as most prevalent:

- Phishing & Spear-Phishing (38%) – Credential-harvesting emails targeting treasury, SWIFT operators, and IT administrators.
- Exposed Remote Desktop Protocol – RDP brute-force attacks on insufficiently secured remote access endpoints remain the leading technical vector.
- Software Supply Chain Compromise – Attackers embed ransomware payloads into trusted third-party vendor updates (e.g., MOVEit, SolarWinds-style attacks).
- Unpatched Vulnerabilities – Exploitation of known CVEs in VPN appliances (Fortinet, Pulse Secure), ESXi hypervisors, and legacy core banking systems.
- Insider Threat – Disgruntled employees or compromised privileged accounts used to disable endpoint detection and deploy payloads.

2.3 Notable Incidents in the Financial Sector

The following case studies underscore the systemic risk ransomware poses to financial infrastructure:

Institution / Event	Year	Impact	Ransomware Family
Tata Power (India)	2022	Operational data exfiltrated; customer records leaked	BlackCat
Bank of Zambia	2022	Central bank IT systems compromised; RaaS ransomware issued	BlackCat
ION Trading UK	2023	Disrupted derivatives reporting for 40+ global banks	LockBit 3.0
Patelco Credit Union (USA)	2024	5.5M customers affected; core banking offline for 2 weeks	BlackCat
Indian Cooperative Bank	2024	Core banking server encrypted; RTGS/NEFT blocked	BlackCat/ALPHV

Table 2: Selected Ransomware Incidents – Financial Sector (2022–2024)

3. SECTOR-SPECIFIC VULNERABILITIES

Financial institutions exhibit a unique vulnerability profile driven by the intersection of legacy infrastructure, high-value data assets, and stringent uptime requirements:

3.1 Legacy Core Banking Systems

A significant proportion of Indian Scheduled Commercial Banks operate core banking solutions (CBS) that run on COBOL-based mainframe architectures, frequently utilising operating systems that have reached end-of-support. These systems cannot accommodate modern endpoint detection agents, creating critical visibility gaps. Ransomware actors specifically target CBS environments because encryption of core transactional databases renders an institution operationally insolvent within hours.

3.2 Interconnected Payment Infrastructure

The UPI ecosystem, RTGS, NEFT, and SWIFT messaging networks create dense interdependencies among financial entities. A ransomware compromise at a single payment service provider or clearing house can produce cascading operational failures across the broader financial system – a systemic risk that regulators must address through mandatory incident notification and isolation protocols.

3.3 Third-Party and Cloud Risk

The outsourcing of IT operations to managed service providers (MSPs) and the adoption of cloud infrastructure (AWS, Azure, GCP) introduces third-party attack vectors. Adversaries increasingly compromise MSPs to deploy ransomware simultaneously across multiple financial institution clients – a force-multiplier tactic documented in both the Kaseya VSA attack (2021) and the Movelt exploitation campaign (2023).

KEY RISK INDICATORS – FINANCIAL SECTOR

- Average dwell time before detection: 16 days (Mandiant M-Trends 2024)
- Mean time to ransomware deployment after initial access: 4.5 hours
- 78% of financial ransomware incidents involve domain administrator credential abuse
- Average ransom demand for Tier-1 Indian banks: USD 3–8 million (estimated, 2024)
- RBI-reported cyber incidents in banking sector: 18,461 cases in FY2023-24

4. REGULATORY AND COMPLIANCE FRAMEWORK

Indian financial institutions operate under a layered regulatory framework that mandates specific cybersecurity controls. Key directives relevant to ransomware preparedness include:

- RBI Master Directions on IT Framework for the NBFC Sector (2017, updated 2023) – mandates IS audit, VAPT, and BCP/DR testing.
- RBI Cyber Security Framework for Banks (2016) – requires Cyber Security Operation Centre (C-SOC), incident response playbooks, and CISO appointment.
- CERT-In Directions (April 2022) – mandatory 6-hour cyber incident reporting, log retention for 180 days, and VPN/cloud audit trails.

- Digital Personal Data Protection Act, 2023 (DPDP Act) – imposes data breach notification obligations and significant financial penalties for non-compliance.
- SEBI Cybersecurity and Cyber Resilience Framework (2024) – applicable to Market Infrastructure Institutions (MIIs) and regulated entities.
- RBI Draft Cyber Resilience and Digital Payment Security Controls (2023) – prescribes specific ransomware recovery time objectives (RTOs) and recovery point objectives (RPOs).

5. RECOMMENDED MITIGATION STRATEGIES

A defence-in-depth approach is imperative. The following mitigation framework is aligned with NIST CSF 2.0 functions and RBI directives:

5.1 Identify & Protect

- Conduct quarterly asset inventory and classify Crown Jewel data assets (CBS databases, SWIFT keys, payment credentials).
- Implement application whitelisting on all servers processing financial transactions.
- Deploy Privileged Access Management (PAM) with Just-in-Time (JIT) access for administrator accounts.
- Patch critical CVEs within 24 hours of CERT-In advisories; enforce automated patch management.
- Establish an immutable, air-gapped backup infrastructure with daily incremental and weekly full backups – tested monthly for restoration integrity.

5.2 Detect & Respond

- Deploy AI/ML-driven Extended Detection and Response (XDR) across all endpoints, servers, and network segments.
- Implement 24x7 Security Operations Centre (SOC) with ransomware-specific detection playbooks and SOAR integration.
- Monitor for precursor indicators: Cobalt Strike beacons, Mimikatz execution, large-volume file access anomalies, and unusual encryption activity.
- Conduct bi-annual Ransomware Simulation Exercises involving IT, Legal, PR, and Executive teams.
- Establish a pre-negotiated Cyber Incident Response Retainer with a qualified DFIR firm.

5.3 Recover & Resilience

- Define and test RTO of less than 4 hours and RPO of less than 1 hour for critical payment systems.
- Maintain an isolated recovery environment (IRE) that can be activated independently of primary infrastructure.
- Implement network segmentation to isolate core banking, payment networks, and internet-facing systems into separate security zones.
- Engage RBI, CERT-In, and NCIIPC within 6 hours of confirmed ransomware incident as per mandatory reporting obligations.
- Preserve forensic evidence (memory dumps, SIEM logs, network captures) prior to initiating recovery to support post-incident investigation.

6. CONCLUSION

Ransomware represents a clear and present danger to the stability, integrity, and continuity of financial services. The convergence of sophisticated threat actors, the Ransomware-as-a-Service ecosystem, and the structural vulnerabilities of legacy financial infrastructure creates a risk environment that demands a proactive, intelligence-led, and institutionally coordinated response.

Financial institutions must transition from reactive incident management to a posture of continuous cyber resilience – encompassing prevention, detection, response, and recovery as integrated capabilities. Regulatory compliance with RBI mandates represents a minimum baseline; genuine resilience requires investment in advanced threat detection, workforce capability development, and cross-sector threat intelligence sharing through platforms such as FSISAC and RBI's own threat sharing portal.

The cost of preparation is measured in thousands; the cost of a ransomware breach in the financial sector is measured in millions of dollars, regulatory sanctions, and the irreparable erosion of customer trust. For institutions operating under RBI's mandate to maintain systemic financial stability, cyber resilience against ransomware is not optional – it is a fiduciary obligation.

REFERENCES

- [1] IBM Security. (2024). Cost of a Data Breach Report 2024. IBM Corporation.
- [2] Reserve Bank of India. (2016). Cyber Security Framework in Banks. RBI/2015-16/418.
- [3] Reserve Bank of India. (2023). Master Directions – Information Technology Framework. RBI.
- [4] CERT-In. (2022). Directions Under Section 70B(6) of the Information Technology Act, 2000. Ministry of Electronics & IT.
- [5] NIST. (2024). Cybersecurity Framework Version 2.0. National Institute of Standards and Technology.
- [6] Mandiant. (2024). M-Trends 2024: Cyber Security Insights Report. Google Cloud.
- [7] Ransomware Task Force. (2023). Mid-Year Update – Ransomware Threat Landscape. IST.
- [8] Verizon. (2024). Data Breach Investigations Report (DBIR) 2024. Verizon Business.
- [9] Ministry of Electronics & IT. (2023). Digital Personal Data Protection Act, 2023. Government of India.
- [10] SEBI. (2024). Cybersecurity and Cyber Resilience Framework for Market Infrastructure Institutions. SEBI/HO/MRD.
- [11] LockBit Ransomware Disruption – Operation Cronos. (2024). Europol / NCA Joint Advisory.
- [12] Palo Alto Networks Unit 42. (2024). Ransomware and Extortion Report 2024. Palo Alto Networks.

This document is prepared for submission to the Reserve Bank of India as a cybersecurity risk assessment white paper. The contents are based on publicly available threat intelligence and regulatory documentation. All statistics are cited from acknowledged industry and regulatory sources.